Лекция 13. Организация информационной безопасности АСОИиУ. Оценка степени компьютерных угроз и уязвимости ресурсов АСОИиУ. Принципы формирования политики информационной безопасности и организации многоуровневой защиты информации в АСОИиУ. Правила организации парольной системы защиты информации на сервере АСОИиУ.

13.1 Организация информационной безопасности АСОИиУ

Нормативные и правоустанавливающие документы

Поскольку сфера информационных технологий постоянно развивается, то также непрерывно совершенствуются и законодательные меры, используемые в этой сфере.

Основополагающими документами по защите информации в Российской Федерации являются:

- Конституция Российской Федерации (принята всенародным голосованием 12 декабря 1993 года) с изменениями и поправками от 30 декабря 2008 года и от 1 июля 2020 года.
- Стратегия национальной безопасности Российской Федерации, которая утверждена Указом Президента РФ от 02.07.2021 г. № 400 "О Стратегии национальной безопасности Российской Федерации". В ней сформулированы важнейшие направления государственной политики РФ в области безопасности.
- Доктрина информационной безопасности Российской Федерации (Указ Президента РФ от 05.12.2016 N 646).

Это совокупность официальных взглядов на цели, задачи, принципы и основные направления обеспечения информационной безопасности в РФ.

Понятно, что это документы глобальные и всеобъемлющие, документы стратегического планирования. А нас с вами интересуют документы менее глобальные, но имеющие более конкретный характер и описывающие практические правила соблюдение которых позволит защитить информацию и систему от несанкционированного доступа и повреждения. Тем не менее на всякий случай разберем с этим сверху до низу.

Информационная безопасность - это состояние защищенности национальных интересов в информационной сфере, определяемых совокупностью сбалансированных интересов личности, общества и государства. В содержании Доктрины нас интересуют организационно-технические и правовые методы обеспечения информационной безопасности.

Организационно-технические методы обеспечения информационной безопасности включают: создание системы информационной безопасности и ее постоянное совершенствование, предотвращение несанкционированного доступа к обрабатываемой информации, контроль за действиями персонала, имеющего доступ к информации, подготовка кадров в области обеспечения информационной безопасности.

Правовые методы обеспечения информационной безопасности предусматривают разработку правовых актов, регламентирующих отношения в сфере информационных технологий (ИТ) и разработку нормативных методических документов по вопросам информационной безопасности.

Организация защиты информации в АСОИиУ предполагает ее полное соответствие требованиям стандартов компьютерной безопасности.

Один из первых стандартов в сфере защиты компьютерной информации, был разработан в 1983 году Министерством обороны США и Национальным комитетом компьютерной безопасности. Этот документ называется «Критерии оценки доверенных компьютерных систем», который, с учетом цвета обложки, часто называют «Оранжевая книга».

Система безопасности, изложенная в «Оранжевой книге», имеет два основных вида требований безопасности: функциональные, и требования доверия, а также поддерживает четыре уровня безопасности: D (низший уровень). C, B, A и включает семь классов безопасности D1, C1, C2, B1, B2, B3, A1, которые соответствуют этим уровням. При этом система безопасности каждого класса должна соответствовать всем требованиям низшего класса и поддерживать все требования своего класса.

Страны Европы (Франция. Германия. Нидерланды и Великобритания) разработали в 1991 году собственные критерии безопасности работы вычислительных систем и назвали их «Критерии оценки безопасности информационных технологий» (Information Technology Security Evaluation Criteria – ITSEQ).

Эти критерии известны также и как «Гармонизированные критерии безопасности европейских стран», они содержат так же семь уровней безопасности от E0 до E6 соответственно в порядке возрастания требований к безопасности и 11 классов безопасности.

В 1999 году был разработан международный стандарт ISO 17799 - «Практические рекомендации по управлению безопасностью информации» («Code of practice for information security management»).

В это же время был разработан еще один международный стандарт ISO/IEC 15408 - «Общие критерии оценки безопасности информационных технологий», который обычно называют сокращенно «Общие критерии», полупивший достаточно широкое распространение.

Так же, как и в «Оранжевой книге» документ «Общие критерии» содержит два основных вида требований безопасности, предъявляемых к информационной системе:

- функциональные требования, которые предъявляются к функциям безопасности системы и реализующим их механизмам:
- требования доверия, которые предъявляются к технологии и процессам разработки и эксплуатации системы.

В отличие от «Оранжевой книги», «Общие критерии» не содержат заранее выделенных классов безопасности. В документе «Общие критерии» угрозы безопасности для информационной системы характеризуются следующими параметрами: источник угрозы, метод воздействия угрозы, уязвимые места системы для угрозы, ресурсы системы, которые подвергаются угрозе.

Позднее были изданы более 30 документов устанавливающих и разъясняющих различные требования в сфере информационной безопасности. Все они имели разноцветные обложки и поэтому среди специалистов известны как «Радужная серия».

Гостехкомиссией РФ также разработан и опубликован ряд руководящих документов, посвященных вопросам защиты информации от несанкционированного доступа.

Пакет включает следующие документы:

- Защита от несанкционированного доступа к информации. Термины и определения.
- Концепция защиты средств вычислительной техники и автоматизированных систем от несанкционированного доступа к информации.
- Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требования по защите информации.
- Средства вычислительной техники. Защита от несанкционированного доступа к информации. Показатели защищённости от несанкционированного доступа к информации.
- Средства вычислительной техники. Межсетевые экраны. Защита от несанкционированного доступа. Показатели защищённости от несанкционированного доступа к информации.
- Защита от несанкционированного доступа к информации. Часть 1. Программное обеспечение средств защиты информации. Классификация по уровню контроля отсутствия недекларированных возможностей.

Согласно этим документам, в России предусмотрены три группы и девять классов защищенности (АИС) от несанкционированного доступа к информации. При этом каждый класс защищенности АИС характеризуется определенной совокупностью требований к средствам защиты.

В пределах каждой группы соблюдается иерархия классов защищенности АИС. В документах используются следующие обозначения: цифра - номер группы, а буква - номер класса внутри группы. Например, 1А - класс «А» первой группы, 1Б - класс «Б» первой группы и т.д.

Группа «1» имеет высшую степень защищенности среди всех групп. Класс «А» соответствует высшей степени защищенности в группе, а класс «Б» следующий по важности класс защищенности в группе и т. д.

Особенности групп защищенности АИС состоят в следующем:

- первая группа включает многопользовательские АИС, в которых одновременно обрабатывается и хранится информация разных уровнен конфиденциальности. Пользователи имеют разные права доступа, а группа содержит пять классов: 1А, 1Б.,1В, 1Г.,1Д;
- вторая группа включает многопользовательские АИС, которых пользователи имеют одинаковые полномочия доступа ко всей информации, обрабатываемой и хранимой в АИС., на носителях различного уровня конфиденциальности, а группа содержит два класса: 2А и 2Б;
- третья группа включает АИС, в которых работает один пользователь, допущенный ко всей информации, размещенной на носителях одного уровня конфиденциальности, группа содержит два класса: 3А и 3Б.

Анализ документов, касающихся вопросов стандартизации защиты компьютерной информации, показывает, что все документы имеют практическую ориентацию и направлены на решение следующих проблем:

- оценка степени угроз информационной безопасности ИС;
- организация информационной безопасности ИС;
- организация многоуровневой защиты информации в ИС.

Организация информационной безопасности АСОИиУ

Согласно ГОСТ Р 50922-2006 «Защита информации. Основные термины и определения», **защита информации** представляет собой деятельность по предотвращению утечки защищаемой информации и несанкционированных воздействий на нее.

Целью защиты информации является сокращение ущерба для владельцев и пользователей защищаемой информации в результате ее возможной утечки или искажения.

Защита информации — это комплекс технических и организационных мероприятий, направленных на обеспечение информационной безопасности и нейтрализацию угроз информационной безопасности.

ГОСТ Р ИСО/МЭК 17799-2005 «Информационная технология. Практические правила управления информационной безопасностью» (Information technology. Code of practice for information security management) содержит определение информационной безопасности (ИБ).

ИСО (Международная организация по стандартизации), МЭК (Международная электротехническая комиссия)

ИБ вычислительных систем — это защищенность данных и поддерживающей инфраструктуры от случайных или преднамеренных воздействий естественного или искусственного характера. Информационная безопасность предусматривает обеспечение конфиденциальности. целостности и доступности информационных ресурсов и поддерживающей их инфраструктуры.

Конфиденциальность информации означает защиту информации от несанкционированного доступа.

Целостность информации означает, что данные, которые находятся на сервере сети, обладают свойствами непротиворечивости, защищенности н актуальности. При этом актуальность подразумевает, что значения данных соответствуют текущему состоянию объекта, который они описывают.

Доступность информации означает, что легальный авторизованный пользователь сети имеет возможность в приемлемое время получить требуемую ему информацию, находящуюся на сервере сели.

Угроза — это потенциальная возможность нарушить информационную безопасность. Попытка реализации угрозы называется атакой, а тот, кто ее предпринимает, является злоумышленником.

Под **угрозой информационной безопасности** обычно понимают возможность нарушения физической целостности информации или ее логической структуры, а также возможность несанкционированного доступа к информации, ее модификации, удаления и размножения.

Компьютерные угрозы делят на следующие два вида:

- неумышленные угрозы, которые имеют место в следующих случаях:
  - ошибочные действия сотрудников при эксплуатации систем вследствие их недостаточной квалификации или безответственности;
  - недостаточная надежность аппаратно-программных средств;
  - недостаточный уровень организации работы системы электропитания, заземления или кондиционирования;
- умышленные угрозы, которые имеют место в следующих случаях:
  - незаконное проникновение в систему злоумышленников;
  - противозаконные действия обиженных пользователей.

Основными источниками угроз информационной безопасности являются:

- отказы программного и аппаратного обеспечения;
- ошибки конфигурации параметров программного обеспечения;
- случайное или умышленное нарушение правил эксплуатации системы;
- действия обслуживающего персонала, нарушающие инструкции;
- нарушение технологии обработки информации;
- внедрение в аппаратные и программные средства компонентов, не предусмотренных документацией;
- повреждение телекоммуникационных систем связи.

Выделяют следующие основные реальные способы реализации угроз:

- компьютерные вирусы и вредоносные программы, которые установлены на компьютер и действуют без разрешения пользователя;
- «маскарад» (злоумышленник действует под видом лица, обладающего полномочиями легального пользователя);
- использование устройств перехвата информации на линиях связи;
- атаки на систему типа «отказ в обслуживании запросов пользователей», при которых злоумышленник запускает очень большое число запросов к выбранному им компьютеру, обычно к серверу, и блокирует его работу.

Уязвимости ресурсов системы - это слабые места в аппаратно-программном и организационном обеспечении АСОИиУ, которые могут быть использованы для реализации угрозы информационной безопасности, например, свободный доступ сотрудников в серверную комнату:

13.2 Оценка степени компьютерных угроз и уязвимости ресурсов АСОИиУ

Для оценки рисков информационной безопасности автоматизированных информационных систем (АИС) в практической деятельности используют методы как качественного, так и количественного анализа.

Базовая модель, разработанная Р. Клеменсом, и предназначенная для описания набора параметров, которые следует учитывать при организации системы информационной безопасности АСОИиУ, имеет следующий вид:

$$S = (R, Y, Z, V, B) \tag{13.1}$$

где: S- набор параметров информационной безопасности системы;

R - набор защищаемых ресурсов информационной системы;

Y - набор угроз информационной системы;

Z - набор средств защиты для обеспечения информационной безопасности;

V - набор уязвимых мест в составе ресурсов системы, представляющих собой пути для возможного проникновения потенциальных угроз в информационную систему;

B - набор барьеров, представляющих собой места в информационной системе, в которые следует установить средства защиты для обеспечения защиты информации от возможной реализации угроз.

Клеменс Ренкер - почетный доктор Санкт-Петербургского государственного экономического университета, профессор

Как правило, в состав защищаемых ресурсов включают все информационные ресурсы, а также системы связи, технические и программные средства обработки информации и помещения, в которых расположены ресурсы системы, подлежащие защите.

Оценку рисков информационной безопасности АСОИиУ обычно рекомендуется осуществлять в следующем порядке.

На этапе 1 следует определить все ресурсы и объекты АСОИиУ, подлежащие защите.

r_j *(j = 1…m)*. где *m* - число ресурсов и объектов, подлежащих защите.

На этапе 2 следует определить:

- типы угроз информационной безопасности Y_i *(i = 1…n)* и оценить вероятности их появления, так p_i *(i = 1...n)* - вероятность появления угрозы *i*-го типа, где *n* - число типов угроз ИБ:
- уязвимые места ресурсов системы, а также вероятности уязвимости ресурсов за счет воздействия на них угроз γ_{ij} *(i = 1...л; j = 1...m)*, где *j* ресурс системы;
- вероятности реализации угроз по отношению к ресурсам системы:

$$p_{ij} = p_i \gamma_{ij}, \quad i = 1 \dots n; \quad j = 1 \dots m \tag{13.2}$$

При задании показателей вероятности появления угроз p_i и вероятности уязвимости ресурсов этими угрозами γ_{ij} рекомендуется использовать качественные (словесные) или количественные (бальные) оценки, как показано на примере оценки угроз в табл. 13.1. При этом уязвимость ресурса также можно оценивать качественно (малая, средняя, большая).

Таблица 13.1

Способы оценки степени появления угрозы

Оценка степени появления угрозы		Средняя частота появления угрозы и атаки
Качественная	Количественная	
Малая (М)	1	Один раз в год
Средняя (С)	2	Один раз в четыре месяца
Большая (Б)	3	Один раз в месяц

На этапе 3 следует определить ценности ресурсов АСОИиУ и оценить уровень их информационной безопасности и системы в целом. Ценность ресурса системы — это экономический показатель, который измеряется в суммарных денежных потерях, затрачиваемых как на восстановление системы после проникновения в нее злоумышленника и реализацию угрозы, так и на потери, имеющие место вследствие утечки информации.

Ценность ресурса также может быть представлена также в виде качественной или количественной (бальной) оценки. Поэтому при качественной оценке ресурс может иметь малую, среднюю н большую ценность.

Далее, используя данные, приведенные в табл. 15.2. проводится оценка уровня ИБ ресурса, на качественном уровне. Уровень информационной безопасности ресурса системы соответствует значению, которое находится на пересечении строки, где указана степень реализации угрозы для ресурса, и столбца, где указана ценность этого ресурса. Например, если степень реализации угрозы для ресурса средняя (С), а ценность этого ресурса малая (М), то уровень информационной безопасности ресурса малый (М).

Таблица 13.2

Оценка уровня информационной безопасности ресурса системы

Степень реализации угрозы	Ценность ресурса системы		
	Малая	Средняя	Большая
Большая	И2	И2	И1
Средняя	И3	И2	И2
Малая	И4	И3	И2

Согласно табл. 13.2 имеют место четыре уровня информационной безопасности ресурсов системы:

уровень И1 - информационная угроза носит недопустимый характер, поэтому внедрение системы защиты информации должно быть выполнено немедленно;

уровень И2 - информационная угроза носит существенный характер, поэтому внедрение системы защиты информации должно быть выполнено в ближайшее время по мере возможности;

уровень И3 - информационная угроза носит допустимый характер, однако требуется провести мониторинг ситуации и по его результатам принять решение о целесообразности принятия мер, противодействующих угрозе, и необходимости внедрения системы защиты информации;

уровень И4- информационная угроза несущественна, поэтому никаких действий по внедрению системы защиты информации, противодействующей данной угрозе, предпринимать пока не требуется.

Для количественной оценки риска ИБ системы (финансовых потерь) следует: определить средние ожидаемые реальные потерн « c » по формуле:

$$c = \sum_{j=1}^{m} c_j = \sum_{i=1}^{n}\sum_{j=1}^{m} p^*_{ij} * c_{ij} \tag{13.3}$$

где c_j - уровень финансовых потерь из-за реализации угроз по отношению к ресурсу *j* -го типа;

c_{ij} - уровень финансовых потерь из-за реализации угрозы *i*-го типа по отношению к ресурсу *j*-то типа;

p^*_{ij} - нормированное значение вероятности реализации информационной угрозы *i* -го типа по отношению к j -му ресурсу.

$$p^*_{ij} = p_{ij} / \sum_{i=1}^{n}\sum_{j=1}^{m} p_{ij} \tag{13.4}$$

где p_{ij} - вероятность реализации угроз *i*-го типа по отношению к *j*-му ресурсу;

n - число типов угроз;

m - число ресурсов системы.

В зависимости от значения величины «*c*», рассчитанной по формуле (13.3), следует принимать соответствующие меры для решения проблемы обеспечения информационной безопасности АС'ОИиУ. Так если значение «*c*» составляет менее 5% финансовых потерь от максимально возможной величины ущерба, то к системе защиты, как правило, претензий нет.

Иначе, чем большую долю от максимально возможной величины ущерба составляет величина «***c***», тем более серьезные требования следует предъявлять к организации системы защиты информации.

На этапе 4 следует сформировать политику информационной безопасности системы, которая представляет собой набор правил и практических рекомендаций по организации защиты информации в АС'ОИиУ, этот набор правил должен утверждаться руководством организации.

Поскольку политика информационной безопасности определяет зоны безопасности АСОИиУ, при ее разработке необходимо соблюдать следующие принципы:

- все запросы к системе должны проходить через защитные средства;
- в системе защитных средств необходимо постоянно усиливать самое слабое звено защиты;
- пользователям предоставлять только те права доступа, которые необходимы для выполнения служебных обязанностей;
- применять многоуровневую защиту для затруднения действий как злоумышленника, так и злонамеренных или неквалифицированных действий обслуживающего персонала и пользователей;
- использовать централизованное администрирование;
- постоянно проводить практическое и теоретическое обучение обслуживающего персонала и пользователей по совершенствованию типовых мер защиты информации.

К числу основных вопросов политики информационной безопасности относятся:

- определение целей политики информационной безопасности;
- создание принципов и правил организации парольной системы защиты;
- создание инструкций по назначению привилегий для различных категорий пользователей и групп пользователей;
- разработка инструкций для пользователей по борьбе с компьютерными вирусами и другими вредоносными программами;
- установление типовых обязанностей пользователей и мер ответственности за нарушение правил работы за компьютерами;
- разработка программ обучения обслуживающего персонала и пользователей вопросам защиты информации;
- создание инструкций по ликвидации последствий нарушения информационной безопасности;
- разработка принципов и правил обновления средств защиты информации.

Разработка политики информационной безопасности завершается созданием плана обеспечения безопасности, т. е. документа, содержащего описание мер. средств и способов реализации информационной безопасности ресурсов и системы в целом, а также необходимую последовательность действий.

На этапе 5 следует определить основные уровни обеспечения информационной безопасности АСОИиУ и все виды средств зашиты, которые нужно использовать на этих уровнях. Отмечу, что для обеспечения информационной безопасности АСОИиУ администраторы и пользователи должны строго соблюдать и выполнять следующие типовые рекомендации:

- использовать только лицензионное ПО;
- своевременно проводить автоматические обновления ОС, рекомендуемые разработчиками программных продуктов;
- не открывать неизвестные письма, полученные по электронной почте;
- осуществлять работу на компьютере в сети Интернет с ограниченными правами пользователя;
- использовать антивирусное ПО и постоянно следить за его обновлением;
- регулярно выполнять сканирование жестких дисков компьютеров в поисках вирусов;

- архивировать файлы с целью минимизации ущерба от вирусной атаки;
- при работе в сети использовать брандмауэр, позволяющий резко снизить степень проникновения на компьютер вредоносного ПО.

13.3 Принципы формирования политики информационной безопасности и организации многоуровневой защиты информации в АСОИиУ

Выделяют следующие уровни многоуровневой защиты информации в АСОИиУ и основные средства защиты, которые следует использовать на этих уровнях.

Уровень 1 — это защита серверов АСОИиУ от несанкционированного доступа. На этом уровне защиты для обеспечения доступа к серверам только легализованных пользователей администратор должен использовать парольную систему защиты, которая обычно включает поддержку следующих трех функций:

1) идентификация пользователя — процедура проверки регистрационного имени пользователя;
2) аутентификация пользователя — процедура проверки подлинности пользователя по введенному им паролю;
3) адресация пользователя — процедура проверки разрешенного по времени входа в сеть и адреса компьютера (или компьютеров), с которых разрешен вход в сеть.

Для удаленного подключения пользователя к серверу следует использовать, например, схему возвратного звонка, которая гарантирует, что удаленный пользователь получил доступ к серверу с разрешенного номера.

Уровень 2 — это защита данных и приложений от атак злоумышленников.

На этом уровне защиты для обеспечения доступа к данным и приложениям только легализованных пользователей администратору следует использовать средства ОС, которые включают поддержку следующих двух функций:

- авторизация пользователя — процедура проверки полномочии и привилегий пользователя на предоставление ему возможности выполнять те действия, которые разрешил администратор;
- апелляция пользователя — процедура ведения и протоколирования действий, совершаемых пользователем на сервере, которые влияют на безопасность информации, расположенной на этом сервере.

Поэтому для каждого пользователя администратор должен установить индивидуальные права на доступ к файлам данных, регламентирующие все действия, которые пользователь может выполнять над этими файлами. Для каждого файла администратор также должен установить индивидуальные атрибуты, регламентирующие возможные действия с этим файлом.

Уровень 3 — это защита узлов АСОИиУ от компьютерных вирусов.

На этом уровне защиты администратору следует устанавливать антивирусные программы. Существует достаточно много программных средств антивирусной защиты.

Современные антивирусные программы состоят из модулей, которые позволяют выявить неизвестные вирусы, обновить вирусную базу данных, проверить, обнаружить и удалить фиксированный набор известных вирусов. Некоторые из этих программ включают также сетевой экран, который обеспечивает защиту компьютера от атак злоумышленников.

Администратор и пользователи должны помнить, что основными признаками наличия вирусов в компьютере являются:

- медленная загрузка и медленная работа компьютера;
- зависания и сбои в работе компьютера;
- неправильная работа ранее успешно работающих программ;
- уменьшение размера свободной области ОП;

- изменение размеров файлов и появление неизвестных файлов;
- исчезновение файлов и каталогов или искажение их содержимого;
- изменение даты и времени модификации файлов;
- частый вывод на экран монитора сообщений об ошибках;
- частое появление на экране монитора всплывающих меню.

Уровень 4 — это защита внутренней сети АСОИиУ от утечки информации при передаче ее между узлами сети. На этом уровне защиты администратору следует использовать специальные протоколы передачи данных, обеспечивающие конфиденциальность информации. Одним из наиболее распространенных протоколов является протокол IP Security.

Уровень 5 — это защита логического (или программного) периметра АСОИиУ от внешних атак злоумышленников за счет использования межсетевого экрана или брандмауэра. Брандмауэр (Firewall) — это компьютер с установленным на нем специальным программным обеспечением, который обеспечивает защиту системы от вторжения злоумышленников из глобальной сети, позволяет пропускать через сетевое подключение системы только авторизованный трафик и осуществляет протоколирование всех событий. Он также может осуществлять шифрование информации, обеспечивать только ее одностороннюю передачу и блокировать нежелательную активность внешнего трафика.

Отметим следующие основные недостатки брандмауэров:

- он обеспечивает эффективную защиту логического периметра АСОИиУ только при очень точной настройке его рабочих параметров, что требует большого опыта работы администратора;
- он не обеспечивает защиту АСОИиУ· от атак, выполняемых изнутри системы, например, «обиженными» пользователями».

Уровень 6 — это защита физического периметра АСОИиУ в результате ограничения доступа персонала в помещения, в которых расположены ресурсы системы. Обслуживающий персонал и пользователи должны иметь право посещать только помещения, выделенные им для выполнения служебных обязанностей.

Поскольку важную роль в организации информационной безопасности АСОИиУ играет парольная система защиты, которую разрабатывает и устанавливает администратор системы, рассмотрим ее более подробно.

Парольную систему защиты сервера АСОИиУ можно представить в виде следующего набора параметров:

$$Y = (L, A, T, N, S, B, R), \tag{13.5}$$

где *L* — длина пароля, т. е. число символов в составе пароля;

A — мощность алфавита пароля, т.е. количество символов, которые могут входить в состав пароля;

T— срок действия пароля, т. е. периодичность изменения пароля;

N— уникальность пароля, т. е. его повторяемость, определяет сколько раз новый пароль не должен повторять старый, или через сколько паролей новый пароль может повторить старый пароль;

S — число входов в систему со старым просроченным паролем после истечения срока его действия;

B — блокировка пароля после неверного его ввода, которая указывает, сколько раз последовательно друг за другом пользователь может неверно набрать и ввести пароль;

R — режим разблокирования пароля, который указывает, через какой промежуток времени и какими средствами возможно провести разблокирование пароля для обеспечения подключения легального пользователя к сети.

Вероятность *P* подбора злоумышленником пароля легального пользователя сети в течение срока действия этого пароля определяется согласно выражению

$$P = \frac{V*T}{W}, \tag{13.6}$$

где *V* — скорость подбора пароля пользователя злоумышленником: *T* — срок действия пароля пользователя; *W* — мощность пространства паролей.

Мощность пространства паролей:

$$W = A^L, \tag{13.7}$$

(*A* — мощность алфавита пароля: *L* — длина пароля пользователя).

После подстановки выражения (13.7) в (13.6) получаем

$$P = \frac{V*T}{A^L}, \tag{13.8}$$

После преобразования выражения (15.8) получаем

$$A^L = \frac{V*T}{P}, \tag{13.9}$$

В результате дальнейшего преобразования выражения (15.9) получаем выражение для определения требуемой длины пароля пользователя в зависимости от срока его действия, скорости и вероятности подбора пароля злоумышленником и мощности алфавита пароля, которое имеет вид

$$L = \frac{ln(V*T/P)}{ln(A)}, \tag{13.10}$$

При задании мощности алфавита пароля А администратор должен учитывать особенности клавиатуры компьютера, принципы работы пользователя за этой клавиатурой, а также требования сетевой ОС. Поэтому администратору рекомендуют использовать следующие способы задания мощности алфавита пароля:

- А = 36, если для набора символов, входящих в состав пароля, используются буквы латинского алфавита без изменения регистра и цифры от 0 до 9;
- А = 62, если для набора символов, входящих в состав пароля, используются буквы латинского алфавита верхнего и нижнего регистров, а также цифры от 0 до 9.

Для задания остальных исходных, входящих в состав выражения (13.8) и необходимых для определения требуемой длины пароля пользователя АСОИиУ, администратору рекомендуют использовать следующие значения:

- срок действия пароля — один месяц, т. е. $T = 30$ сут. $= 720$ ч $= 2.592\ 10^6$с;
- скорость подбора пароля пользователя злоумышленником с использованием современных компьютеров при отсутствии режима блокировки пароля изменяется в пределах от $v = 10^5$ до $v = 10^7$ паролей/с;
- вероятность подбора злоумышленником пароля администратора - не более 10^{-12}, пользователя, решающего важные задачи. - не более 10^{-10}, а обычного пользователя - не более 10^{-8}.

Результаты расчетов, проведенных с использованием выражения (13.10) при подстановке в него рекомендуемых числовых значений исходных данных без использования режима блокировки ввода пароля, приведены в табл.13.3.

Таблица 13.3

Выбор длины пароля

Вероятность подбора пароля *P*	Длина пароля *L*					
	A = 36			*A* = 62		
	$v = 10^5$	$v = 10^6$	$v = 10^7$	$v = 10^5$	$v = 10^6$	$v = 10^7$
10^{-15}	16.98	17.63	18.28	14.72	15.29	15.84
10^{-12}	15.06	15.70	16.35	13.06	13.61	14.17
10^{-10}	13.77	14.43	15.06	11.94	12.50	13.06
10^{-8}	12.43	13.13	13.77	10.82	11.38	11.94

При использовании режима автоматической блокировки ввода пароля в случае нескольких *n* последовательных неверных попыток ввода пароля ОС будет автоматически осуществлять блокировку его дальнейшего ввода на некоторый промежуток времени.

Скорость подбора злоумышленником пароля пользователя при наличии блокировки существенно снижается по сравнению с ее отсутствием и определяется из выражения

$$V_{\text{бл}} = \frac{n}{T_{\text{бл}}}, \tag{13.11}$$

Типовые значения времени блокировки ввода пароля пользователя и скорости подбора пароля, вычисленные по выражению (13.11). при числе неверных попыток ввода пароля *n* = 3, которое наиболее широко используют администраторы в их практической работе, приведены в табл. 13.4.

Таблица 13.4

Связь времени блокировки и скорости подбора пароля

Время блокировки ввода пароля, устанавливаемое администратором сети, мин	$T_{\text{бл}}$, сек	Скорость подбора пароля при наличии блокировки $V_{\text{бл}}$ паролей, с
15	900	0.003333
5	300	0.01
1	60	0.05

При использовании режима автоматической блокировки ввода пароля выражение для определения требуемой длины пароля пользователя с учетом выражений (13.10) и (13.11) имеет вид

$$L_{\text{бл}} = \frac{ln(V_{\text{бл}}*T/P)}{ln(A)}, \tag{13.12}$$

где $L_{\text{бл}}$ — длина пароля пользователя при наличии режима блокировки ввода пароля.

При этом количество символов ΔL, на которое уменьшается длина пароля при его блокировке, можно определить из выражения

$$\Delta L = L - L_{\text{бл}} = \frac{ln(V*T/P)}{ln(A)} - \frac{\ln ln\left(V_{\text{бл}}*\frac{T}{P}\right)}{\ln ln\,(A)} = \frac{ln(V/V_{\text{бл}})}{ln(A)}, \tag{13.13}$$

При расчетах $ln(A)$ принимает следующие значения: $l(36) = 3.58$ и $l(62) = 4.13$. Исходные данные для расчета $A,\ V,\ V_{\text{бл}}$, а также значения ΔL, вычисленные по выражению (13.13). приведены в табл. 13.6

Анализ результатов, приведенных в табл. 13.5 показывает, что использование режима блокировки ввода пароля пользователя позволяет уменьшить длину пароля пользователя на 4-5 символов, обеспечивая надлежащий уровень защиты сервера от проникновения на него злоумышленников.

Таблица 13.5

Уменьшение длины пароля за счет использования режима блокировки

$V_{\text{бл}}$ паролей, сек	Уменьшение длины пароля AL при использовании режима блокировки пароля					
	A = 36			*A* = 62		
	$v = 10^5$	$v = 10^6$	$v = 10^7$	$v = 10^5$	$v = 10^6$	$v = 10^7$
0.003333	4.80	5.45	6.10	4.16	4.73	5.28
0.01	4.50	5.15	5.79	3.92	4.46	5.02
0.05	4.05	4.70	5.34	3.51	4.07	4.63

13.4 Правила организации парольной системы защиты информации на сервере АСОИиУ

Следует дать основные рекомендации администратору по формированию парольной системы защиты сервера:

1) на сервере ЛВС целесообразно установить режим автоматической блокировки ввода пароля пользователя, при котором после трех неверных попыток подключения пользователя к серверу вход в сеть блокируется на время, не менее одной минуты, при повторных неверных вводах пароля, время блокировки увеличивается;
2) пароль пользователя не должен содержать осмысленных слов из словаря, чтобы резко уменьшить скорость его подбора;
3) пароль пользователя не должен представлять собой слово, которое часто употребляет пользователь;
4) пароль пользователя должен соответствовать алфавиту А = 62 и содержать символы верхнего и нижнего регистров клавиатуры компьютера;
5) пароль пользователя должен содержать не менее 7 символов, включать строчные и прописные буквы, а также цифры;
6) пароль пользователя должен иметь ограниченный срок действия, но не более 30 сут.

Рекомендации по генерации надежных паролей

В 2017 году Национальный институт стандартов и технологий США (NIST) обновил парольные спецификации, которые рекомендуются в качестве стандартов NIST. Новые требования изложены в Специальной публикации NIST 800-63B, раздел 5.1.1.2 «Запоминаемые секретные верификаторы» (NIST, 2017).

Основные требования NIST 800-63B для верификаторов (компаний и организаций), которые устанавливают собственные парольные политики:

1. Верификаторы не должны устанавливать правила составления паролей, например, требовать сочетания различных типов символов или запрещать последовательное повторение символов.
2. Верификаторы не должны требовать произвольной или регулярной смены паролей, как, например, предыдущее правило 90 дней. С другой стороны, смена пароля должна быть обязательной в случае его компрометации.
3. Пароли должны быть длиной не менее 8 символов.
4. Системы паролей должны позволять абонентам выбирать пароли длиной не менее 64 символов.

5. В паролях должны быть допустимы все печатные символы ASCII, символ пробела и символы Unicode.
6. При установлении или изменении паролей верификатор должен сообщить абоненту, что ему необходимо выбрать другой пароль, если он выбрал слабый или скомпрометированный пароль.
7. Верификаторы должны предлагать рекомендации, например, измеритель стойкости пароля, чтобы помочь пользователю выбрать надежный пароль.
8. Верификаторы должны хранить пароли в форме, устойчивой к офлайновым атакам. К паролям следует добавлять соль и хэшировать с помощью подходящей односторонней функции деривации ключа. Функции выработки ключа принимают на вход пароль, соль и требуемые вычислительные ресурсы (cost factor), а затем генерируют хэш пароля. Их цель — сделать каждую попытку угадывания пароля злоумышленником, получившим хэш-файл пароля, дорогостоящей и, следовательно, стоимость атаки на угадывание высокой или запретительной.

Дополнительно, в вопросах B05 и B06 в разделе FAQ документации NIST к обновленным специальным публикациям (NIST, 2020) организация официально пояснила, что обязательная смена пароля «снижает общую безопасность системы паролей» и не должна использоваться. Согласно объяснению NIST, периодическая смена паролей снижает их энтропию. Хотя это довольно спорный вопрос, по которому нет единого мнения.

Кроме того, нет единого мнения и по всем остальным правилам генерации паролей, включая минимальную длину, минимальную энтропию, наличие/отсутствие спецсимволов.

В качестве примера можно привести рекомендации по созданию надежных паролей от ведущих компьютерных корпораций: Microsoft и Google.

Microsoft

Советы по созданию защищенных паролей:

Минимум 12 символов, лучше от 14-ти

Буквы в верхнем и нижнем регистрах, цифры и символы

Запрещено использовать слова из словаря, а также имена людей, символов, продуктов и компаний

Пароль должен значительно отличаться от предыдущих паролей пользователя

Простая в запоминании, но трудная для подбора фраза. В качестве примера Microsoft приводит 6MonkeysRLooking

Google

Рекомендации для паролей:

Минимум 12 символов

Буквы в верхнем и нижнем регистрах, цифры и символы ASCII

Google рекомендует максимально увеличивать энтропию пароля, создавая очень длинные пароли. Чтобы их было легче запомнить, можно брать знакомые отрывки текста:

Лирика из песни или стихотворения

Осмысленная цитата из фильма или речи

Отрывок из книги

Серия слов, которые имеют для вас значение

Аббревиатура: можно составить пароль из первой буквы каждого слова в предложении

Контрольные вопросы и задания

1. Перечислите основополагающие документы по защите информации в Российской Федерации.
2. Поясните назначение Доктрины информационной безопасности РФ.
3. Перечислите уровни правового обеспечения защиты информации и документы, соответствующие этим уровням.
4. Перечислите документы, которые входят в систему стандартов информационной безопасности
5. Поясните назначение документа «Оранжевая книга».
6. Что составляет сходство и в чем различие документов «Критерии оценки безопасности информационных технологий» и «Общие критерии оценки безопасности информационных технологий».
7. Поясните различие между документами «Оранжевая книга» и «Общие критерии оценки безопасности информационных технологий».
8. Поясните назначение групп и классов, изложенных в документе по защите информации от несанкционированного доступа, разработанном Гостехкомиссией России.
9. Поясните понятие защита информации.
10. Что такое информационная безопасность АСОИиУ?
11. Приведите выражения для оценки меры уязвимости ресурса АСОИиУ.
12. Перечислите этапы организации информационной безопасности АСОИиУ.
13. Поясните назначение уровней защиты информации в АСОИиУ.
14. Перечислите средства, которые следует использовать администратору при защите информации в АСОИиУ?
15. Приведите правила формирования парольной системы защиты сервера.